

Identity and Access Management

Identity and Access Management (IAM)

Applications are available anywhere:

- Desktop, browser, mobile device, etc.

Data can be located anywhere:

- Cloud storage, private data centers, etc

Many different application users:

- Employees, vendors, contractors, customers

Give the right permissions to the right people at the right time:

Prevent unauthorized access

Identify lifecycle management:

- Entry entity (human and non human) gets a digital identity

Access control:

- An entity only gets access to what they need

Authentication and Authorization:

- Entities must prove they are who they claim to be

Identity governance:

- Track an entity's resource access
- May be a regulatory requirement

Provisioning/de-provisioning user accounts:

The user account creation process:

- An the account removal process

Provisioning and de-provisioning occurs for certain events:

- Hiring, transfers, promotions, job separation

Account details:

- Name, attributes, group perms, other perms

An important part of the TIAM process:

- An initial checkpoint to limit access
- Nobody gets admin access

Permission assignments;

Each entity gets limited permissions:

- Just enough to do their job
- Group assignments are common

Storage and files can be private to that user:

- Even if another person is using the same computer

No privileged access to the operating system:

- Specifically not allowed on a user account

Identity proofing:

I could be anyone:

- The IAM process should confirm who I am

Resolution:

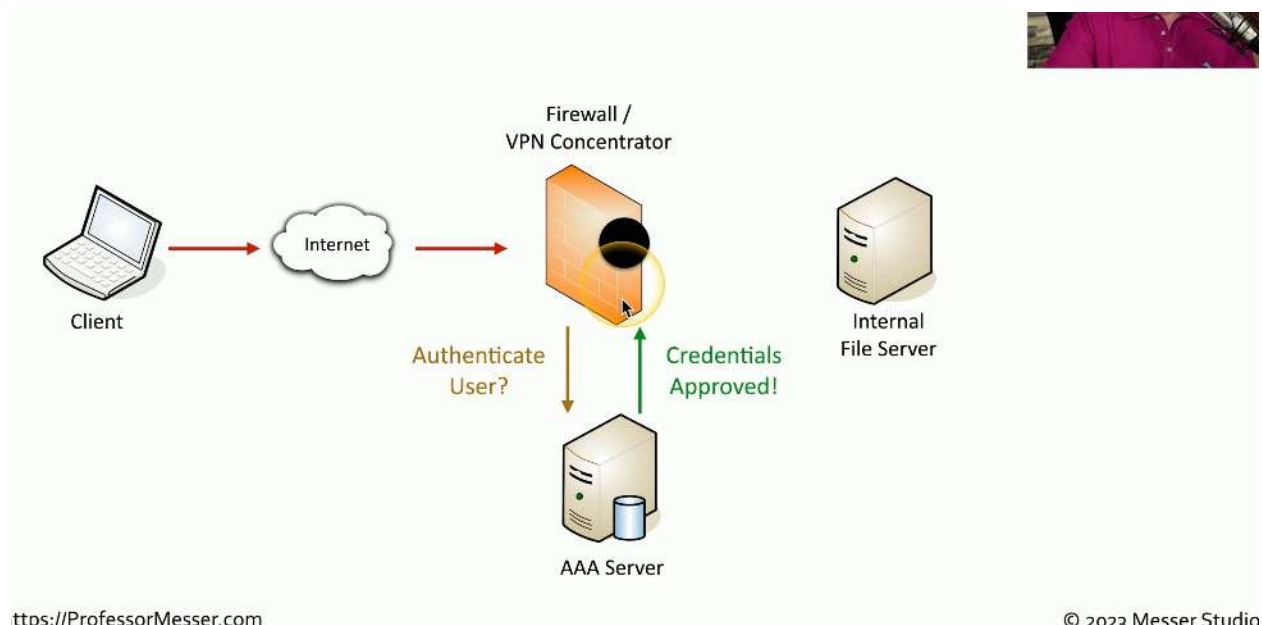
- Who the system thinks you are

Validation:

- Gather information from the user

Verification/Attestation:

- Passport, inperson meeting
- Automated verification options



SSO or single sign on:

Provide creds one time:

- Get access to all available or assigned resources
- No additional authentication required

Usually limited by time:

- A single authentication can work for 24 hours or whatever the company policy is set too
- Authenticate again after timer is up

The underlying authentication infrastructure must support SSO:

- Not always an option

LDAP (Lightweight Directory Access Protocol):

Protocol for reading and writing directories over an IP network:

- An organized set of records, like a phone directory

X.500 specification was written by the international Telecommunications Union (ITU)

- They know directories

DAP ran on the OSI protocol stack:

- LDAP is lightweight

LDAP is the protocol used to query and update an X.500 directory :

- Used in Windows Active Directory, Apple OpenDirectory, Novell eDirectory etc.

X.500 Distinguished names:

Attribute = value pairs

Most specific attribute is listed first:

- This may be similar to the way you already think

CN=WIDGETWEB, OU=Marketing, O=Widget, L=London, ST=London, C=GB, DC=widget, DC=com

Attribute	Field	Usage
CN	Common Name	Identifies the person or object.
OU	Organizational Unit	A unit or department within the organization.
O	Organization	The name of the organization.
L	Locality	Usually a city or area.
ST	State	A state, province, or county within a country.
C	Country	The country's 2-character ISO code (such as c=US or c=GB).
DC	Domain Component	Components of the object's domain.

//ProfessorMesser.com

© 2023 Messer Studio

X.500 Directory Information Tree:

Hierarchical structure:

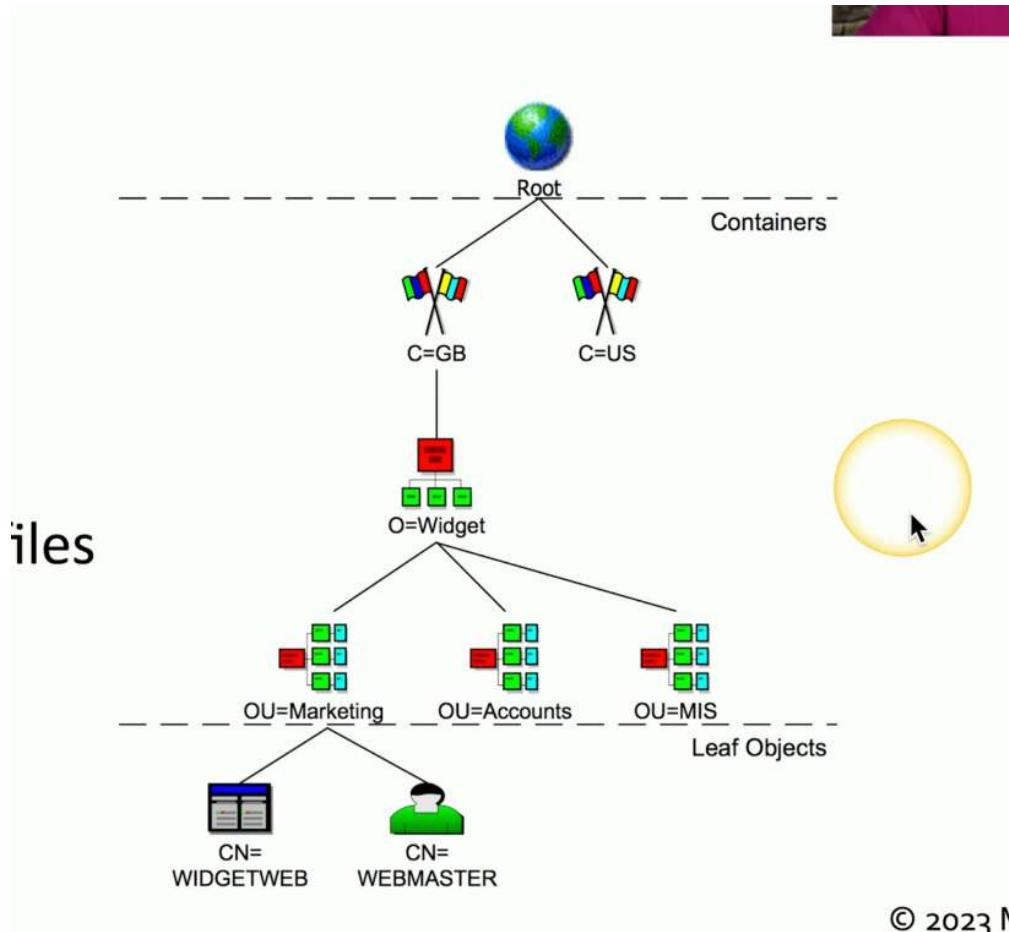
- Builds a tree

Container objects:

- country, organization, organizational units

Leaf objects:

- Users Computers, printers, files



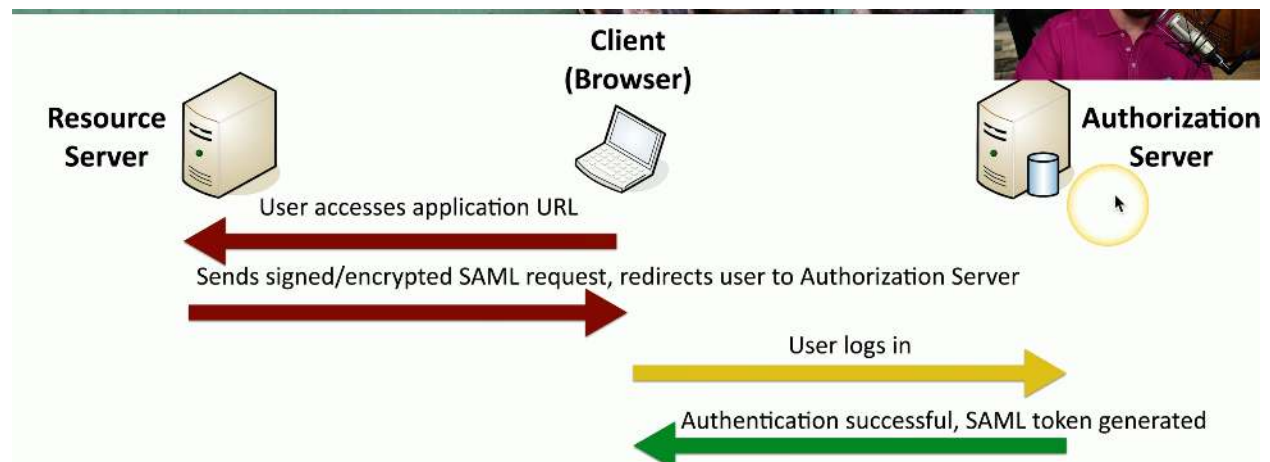
Security Assertion Markup Language (SAML):

Open standard for authentication and authorization:

- You can authenticate through a third party to gain access
- One standard does it all, sort of

Not originally designed for mobile apps:

- This has been SAML's Largest roadblock



OAuth

Authorization framework:

- Determines what resources a user will be able to access

Created by Twitter Google and many other:

- Significant industry support

Not an authentication protocol:

- OpenID Connect handles single sign-on authentication
- OAuth provides authorization between apps

Federation;

Provide network access to others:

- Not just employees - Partners, suppliers, customers, etc
- Provides SSO and more

Third parties can establish a federated network:

- Authenticate and authorize between the two organizations
- Login with your Facebook creds

The third parties must establish a trust relationship:

- And the degree of trust

Interoperability:

Many different ways to communicate with an authentication server:

- More than. A simple login process

Often determined by what is at hand:

- VPN concentrated can talk to a LDAP server
- We have an LDAP server

A new app uses OAuth:

- Needs to allow authentication. API access

The interoperability is dependent on the environment:

- This is often part of a much larger IAM strategy

Access Controls

Authorization:

- The process of ensuring only authorized rights are exercised
- Policy enforcement
- The process of determined rights
- Policy definition

Users receive rights based on Access control models:

- Different business needs or mission requirements

Least Privilege:

Rights and perms should be set to bare minimum

All users accounts must be limited

Dont allow users to run with admin privileges

Mandatory Access Control (MAC):

The operating system limits the operation on an object:

- Based on security clearance levels

Every object gets a label:

- Confidential, secret, top secret, etc

Labeling of objects uses predefined rules:

- The admin decides who gets access to what security level
- Users cannot change these settings

Discretionary Access Control (DAC):

Used in most OS:

- A familiar access control model

You create a spreadsheet:

- As the owner, you control who has access
- You can modify access at any time

Very flexible access control:

- And very weak security

Role based access control (RBAC)

Your role determines the perms the user gets

Admins provide access perms to users with specific roles

Rule Based Access Control:

Generic term for following rules:

- Conditions other who you are

Access is determined through system enforced rules:

- System admins not users

Rule example:

- Lab network access is only available from 9-5.

Attribute based access control (ABAC):

Users can have complex relationships to apps and data

- Access ay be based on many different criteria

ABAC can consider many parameters:

- A next generation authorization model
- Aware of context

Combine and evaluate multiple parameters

Time of day restrictions:

Restrict access based on time of the day

Multi Factor Authentication

Proves who you are:

- Use different methods
- A memorized password
- A mobile app
- Your GPS location

You know what this is just use ur brain bud

Password Security

Make a password string:

- Resist Guessing or brute force attack

Increase password entropy:

- No single words, no obvious passwords
- Mix upper and lower case letters and special chars.

Just dont be a dummy and just create a strong password

Password Age;

- how long since password has changed

Password expiration:

- Timer on password

Critical systems need alot of password changes

Use different passwords with every account and store them in a password manager

OS's now have built in password managers

Passwordless authentication:

Many breaches are due to poor password control:

- Weak passwords, insecure implementation

Authenticate without password

You may already be passwordless

Passwordless may not be the primary authentication method

Just in time perms:

In orgs, the IT team is assigned admin/root elevated account right:

- This would be a great account to attack

Grant admin access for a limited time:

- No permanent admin rights
- The principle of least privilege

A breached user account never has elevated rights

Just in time creates a time limited account:

- Admins receives ephemeral creds
- Primary passwords never released
- Creds are used for one session then deleted